

Cyber Security - Continuous Monitoring Plan

Plan Statement

Advanced Personnel Management (**APM**) is committed to actively and effectively managing access to APM IT devices, resources, and services (**APM IT assets**) to enable APM to provide a safe, secure and readily accessible environment in which to work.

Objectives

- To communicate the need for continual monitoring of APM IT systems
- Provide awareness of threats and vulnerabilities, visibility into APM assets, and the effectiveness of deployed security control.

Continuous Monitoring

Cyber threats and the effectiveness of the security control will change over time. A continuous monitoring (CONMON) plan can assist in proactively identifying, prioritising and responding to security vulnerabilities.

The monitoring and managing of security vulnerabilities can also provide valuable information about the exposure to cyber threats and determining security risks associated with the operation of APM IT systems.

CONMON activities must be conducted by a member of the Cyber Security Team or by personnel who possesses similar skillset who is independent of the system being assessed and can be internal or third party. This ensures that there is no conflict of interest, perceived or otherwise, and that the activities are undertaken in an objective manner.

"Maintaining ongoing awareness of information security, vulnerabilities, and threats to facilitate organizational risk management decisions."¹

CONMON

- involves ongoing assessment and analysis of the effectiveness of all security controls
- provides ongoing reporting on the security posture of information systems, and
- supports risk management decisions to help maintain organisational risk tolerance at acceptable levels.

¹ https://csrc.nist.gov/glossary/term/information_security_continuous_monitoring

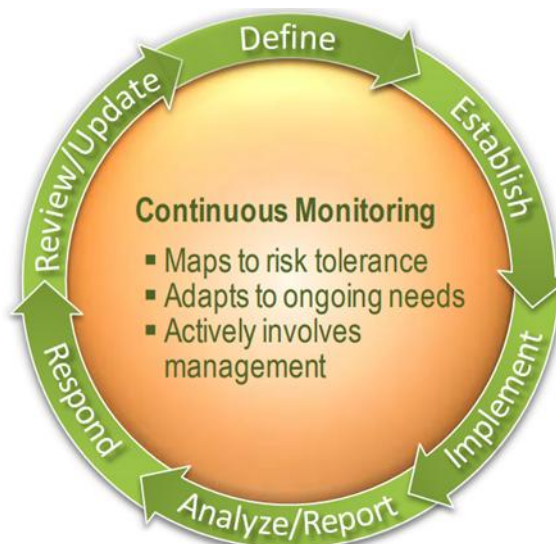


Figure 1: NIST Continuous Monitoring Process²

NIST SP 800-137 recommends a systematic approach to continuous monitoring to ensure mapping of risk tolerance, adapting to ongoing business requirements, management involvement, as well as having several inputs into the continuous monitoring process for a holistic viewpoint, including:

- Assess all security controls
- Collect and correlate security data
- Report on security posture
- Facilitate risk-based decisions.

Threat Landscape

The information security threat landscape should be continuously monitored with threat reports being reviewed and analysed and incorporated into APM's Risk Management documents including Enterprise and Business Unit Operation Risk Registers.

Opensource threat reports such as those provided by the Australian Cyber Security Centre (ACSC)³ and other reputable sources, should be referred to for information about current security threats.

Threat landscape information is monitored by the Cyber Security team on a daily basis and relayed to the relevant business teams as required.

Vulnerability Management

Vulnerability management is an essential activity which is at the core of information security monitoring and is a cornerstone of security for all ICT systems. All APM systems are continuously monitored for vulnerabilities using the Defender for Cloud and Defender for Endpoint solutions. Weekly meetings are held between the Cyber Security team and Digital Operations teams to review results and remediation activities as per the APM *Patch & Vulnerability Management Standard*.

² <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-137.pdf>

³ <https://www.cyber.gov.au/about-us/view-all-content/reports-and-statistics/asd-cyber-threat-report-july-2022-june-2023>

The following activities will assist in identifying vulnerabilities:

- Vulnerability Assessments - identifying vulnerabilities the system is exposed to
- Vulnerability Analysis – determining the risk posed by the vulnerability, and
- Vulnerability Mitigation – remediating known system vulnerabilities.

Vulnerability Assessments

A vulnerability assessment typically consists of a review of a system's architecture or an in-depth hands-on assessment, while a vulnerability scan involves using software tools to conduct automated or semi-automated scans of ICT systems and environments.

Vulnerability assessments allow the identification of security weakness which may have been caused by misconfigurations, bugs, or flaws in APM IT systems.

Vulnerability assessment for APM IT systems should be performed:

- For new systems before they are deployed
- On systems or networks whenever major/significant changes occur
- Where new or significant threats are identified
- As a result of a specific security incident, and
- At regular intervals to determine if new vulnerabilities have been identified since the most recent assessment.

Vulnerability assessment for the APM IT systems should be conducted by suitably skilled personnel who is independent of the system owner, or by a third party who is independent of the target of the assessment.

Vulnerability scan as part of assessments may be performed either by:

- Using automated assessment tools
- or
- Manually by appropriately skilled ICT professionals.

Penetration Testing

A penetration test is a method of evaluating the security of an ICT system or environment by simulating an attack from malicious parties to reveal weaknesses in the code base or protections surrounding a system or network. Penetration tests generally attempt to exploit identified vulnerabilities and gain access to a system or network.

Penetration testing should be used to identify new vulnerabilities in an APM IT system, test existing mitigations and security posture, and simulate attacks that could be executed by attackers with varying levels of system knowledge.

Penetration testing for APM IT systems should be performed:

- Prior to a system going 'live'
- After material upgrades or modifications to the technology environment, and
- at an appropriate frequency, generally annually.

Before penetration testing is performed, approval is required from the system owners of all ICT systems and environments within the defined scope.

Penetration testing should be performed at a time that will minimise impacts to the APM IT system if the penetration testing results in the system becoming unavailable or degrades performance.

All key existing APM systems are penetration tested on an annual basis. A schedule of Penetration Testing is agreed with Systems Owners and approved by the CISO. Testing is completed by the Cyber Security team or external penetration testers depending on any contractual requirements associated with the system.

Vulnerability Monitoring

A host-based intrusion prevention system (HIPS) uses behaviour-based detection schemes to assist in identifying and blocking anomalous behaviour, such as process injection, keystroke logging, driver loading and call hooking, as well as detecting malicious code that has yet to be identified by antivirus vendors.

Network-based intrusion detection systems (NIDS) and network-based intrusion prevention systems (NIPS) when configured correctly, kept current, and supported by suitable processes and resources, can be an effective way of identifying and responding to known intrusion profiles.

Generating alerts for information flows that contravene firewall rules helps security personnel respond to malicious or suspicious traffic entering a network due to a failure or configuration change to firewalls. Analysis of these incidents may allow unknown vulnerabilities to be identified.

Vulnerability Scanning

A vulnerability scan is designed to test and analyse ICT systems and environments for known vulnerabilities. The scan comprises a list of scan options (ports, protocols, and network packet behavioural characteristics used for scanning) and assets. A report is produced that contains a prioritised list of vulnerabilities, vulnerability descriptions, calculated risk score, and recommended remediation activities.

Conducting vulnerability scanning on APM IT systems will ensure that staff are aware of the latest threats to infrastructure and the risks posed by such threats.

Vulnerability Reporting will report the findings of any vulnerability scanning and is an essential part of ensuring that risks to APM IT systems are made known to appropriate staff and highlight the potential impacts they may have on systems.

The APM IT system utilises Microsoft Defender for Endpoint⁴ (continuously) for identifying vulnerabilities on the corporate network and on-premise work devices.

Wiz.io is used to (continuously) monitor APM's cloud service environments for any configuration issues that could expose APM to an attack.

Vulnerability Analysis

Vulnerability analysis involves reaching an understanding of the potential impacts of identified vulnerabilities, associated mitigation options and implementation considerations, such as:

- What is the impact if the vulnerability is exploited?
- What are the available mitigation techniques?
- How effective are those mitigations likely to be?
- Who is responsible for implementing any mitigations?
- What will the cost of implementing the mitigations be?

Mitigation efforts should be prioritised using the Vulnerability Mitigation Process below, to address the most significant vulnerabilities first.

⁴ <https://www.microsoft.com/en-au/security/business/endpoint-security/microsoft-defender-endpoint>

Vulnerability Mitigation

Vulnerability Mitigation is the actions taken to mitigate vulnerabilities in a risk-based and timely manner. Mitigations often take the form of applying vendor-issued patches. Where a patch is not currently available, vulnerabilities must be mitigated in other ways. Any vulnerability mitigations must be addressed.

Prevent exploitation of vulnerabilities by:

- applying input validation and/or sanitisation
- applying filtering or verification of output
- applying additional access controls
- configuring firewall rules to limit access to systems containing identified vulnerabilities.

Detect exploitation of vulnerabilities by:

- deploying an intrusion detection system (IDS)
- monitoring of logged alerts, and
- using other mechanisms for the detection of known exploits of the identified vulnerabilities.

Contain exploitation of vulnerabilities by:

- applying firewall rules limiting or preventing outbound traffic
- implementing mandatory access control preventing the execution of exploitation code, and
- setting file system permissions preventing exploitation code from being written to disk.

Resolve vulnerabilities by:

- disabling the functionality associated with the security vulnerability
- asking the vendor for guidance on alternative method(s) of managing the vulnerabilities in their product(s)
- migrating to a different product that are not affected by the identified vulnerabilities, or where the identified vulnerabilities have already been mitigated, and
- engaging a software developer to resolve the security vulnerability.

Mitigations should be prioritised based on risk to APM IT System systems and data. Personnel must implement mitigations or otherwise treat identified vulnerabilities as soon as practicable.

Related Legislation or Policy

- Information Security Policy
- Cyber Security - Patch and Vulnerability Management Standard

Supporting Documents

This document is to be used in conjunction with:

Patch and Vulnerability Management Standard

Business Area Contact

Cyber Security, Corporate Services

Review

Update this document whenever requirements change and review at least every year.